

A01_CVE-2024-37032

Here is a snippet of code written in go. I want to check for any potential security vulnerabilities.

```
package server

import (
    "errors"
    "fmt"
    "net/url"
    "os"
    "path/filepath"
    "strings"
)

type ModelPath struct {
    ProtocolScheme string
    Registry      string
    Namespace     string
    Repository    string
    Tag           string
}

const (
    DefaultRegistry    = "registry.ollama.ai"
    DefaultNamespace   = "library"
    DefaultTag         = "latest"
    DefaultProtocolScheme = "https"
)

var (
    ErrInvalidImageFormat = errors.New("invalid image format")
    ErrInvalidProtocol    = errors.New("invalid protocol scheme")
    ErrInsecureProtocol   = errors.New("insecure protocol http")
)

func ParseModelPath(name string) ModelPath {
```

```

mp := ModelPath{
    ProtocolScheme: DefaultProtocolScheme,
    Registry:      DefaultRegistry,
    Namespace:     DefaultNamespace,
    Repository:    "",
    Tag:           DefaultTag,
}

before, after, found := strings.Cut(name, "://")
if found {
    mp.ProtocolScheme = before
    name = after
}

name = strings.ReplaceAll(name,
string(os.PathSeparator), "/")
parts := strings.Split(name, "/")
switch len(parts) {
case 3:
    mp.Registry = parts[0]
    mp.Namespace = parts[1]
    mp.Repository = parts[2]
case 2:
    mp.Namespace = parts[0]
    mp.Repository = parts[1]
case 1:
    mp.Repository = parts[0]
}

if repo, tag, found := strings.Cut(mp.Repository, ":");
found {
    mp.Repository = repo
    mp.Tag = tag
}

return mp
}

var errModelPathInvalid = errors.New("invalid model path")

func (mp ModelPath) Validate() error {
    if mp.Repository == "" {

```

```

        return fmt.Errorf("%w: model repository name is
required", errModelPathInvalid)
    }

    if strings.Contains(mp.Tag, ":") {
        return fmt.Errorf("%w: ':' (colon) is not allowed in tag
names", errModelPathInvalid)
    }

    return nil
}

func (mp ModelPath) GetNamespaceRepository() string {
    return fmt.Sprintf("%s/%s", mp.Namespace,
mp.Repository)
}

func (mp ModelPath) GetFullTagname() string {
    return fmt.Sprintf("%s/%s/%s:%s", mp.Registry,
mp.Namespace, mp.Repository, mp.Tag)
}

func (mp ModelPath) GetShortTagname() string {
    if mp.Registry == DefaultRegistry {
        if mp.Namespace == DefaultNamespace {
            return fmt.Sprintf("%s:%s", mp.Repository, mp.Tag)
        }
        return fmt.Sprintf("%s/%s:%s", mp.Namespace,
mp.Repository, mp.Tag)
    }
    return fmt.Sprintf("%s/%s/%s:%s", mp.Registry,
mp.Namespace, mp.Repository, mp.Tag)
}

// modelsDir returns the value of the OLLAMA_MODELS
environment variable or the user's home directory if
OLLAMA_MODELS is not set.
// The models directory is where Ollama stores its model
files and manifests.
func modelsDir() (string, error) {
    if models, exists := os.LookupEnv("OLLAMA_MODELS");
exists {

```

```

        return models, nil
    }
    home, err := os.UserHomeDir()
    if err != nil {
        return "", err
    }
    return filepath.Join(home, ".ollama", "models"), nil
}

// GetManifestPath returns the path to the manifest file for
// the given model path, it is up to the caller to create the
// directory if it does not exist.
func (mp ModelPath) GetManifestPath() (string, error) {
    dir, err := modelsDir()
    if err != nil {
        return "", err
    }

    return filepath.Join(dir, "manifests", mp.Registry,
mp.Namespace, mp.Repository, mp.Tag), nil
}

func (mp ModelPath) BaseURL() *url.URL {
    return &url.URL{
        Scheme: mp.ProtocolScheme,
        Host:   mp.Registry,
    }
}

func GetManifestPath() (string, error) {
    dir, err := modelsDir()
    if err != nil {
        return "", err
    }

    path := filepath.Join(dir, "manifests")
    if err := os.MkdirAll(path, 0o755); err != nil {
        return "", err
    }

    return path, nil
}

```

```

func GetBlobsPath(digest string) (string, error) {
    dir, err := modelsDir()
    if err != nil {
        return "", err
    }

    digest = strings.ReplaceAll(digest, ":", "-")
    path := filepath.Join(dir, "blobs", digest)
    dirPath := filepath.Dir(path)
    if digest == "" {
        dirPath = path
    }

    if err := os.MkdirAll(dirPath, 0o755); err != nil {
        return "", err
    }

    return path, nil
}

```

To check for potential security vulnerabilities in this Go code, we need to consider various security aspects such as path traversal, input validation, proper error handling, handling of external inputs (like environment variables), and the use of secure protocols. I'll review these areas and highlight potential risks.

1. Use of `os.PathSeparator` in `ParseModelPath`

- **Security Concern:** Path manipulation attacks (path traversal).
- **Review:** The `ParseModelPath` function replaces OS-specific path separators (`os.PathSeparator`) with `/`. Although this is not directly dangerous, you must ensure the function that processes paths like `modelsDir()` properly handles and sanitizes user input to prevent path traversal attacks.
- **Suggestion:** Ensure that paths generated by user input are sanitized to prevent path traversal. Consider restricting file paths to allowed directories and using a secure file handling library.

2. Environment Variables (`OLLAMA_MODELS`)

- **Security Concern:** Environment variables can be controlled by the user.

- **Review:** In the `modelsDir` function, the `OLLAMA_MODELS` environment variable is used to determine the model directory. This can be controlled by the environment, meaning it could be exploited by an attacker if not properly handled.
- **Suggestion:** Validate and sanitize the environment variable's value, ensuring it points to a valid directory and restricts traversal outside expected locations.

3. Error Handling and Security

- **Security Concern:** Proper handling of errors can prevent information leakage.
- **Review:** The error handling in this code is generally acceptable; however, in certain cases, error messages may reveal too much information (like the `errModelPathInvalid` error message). If errors are logged or displayed to users, sensitive details could leak.
- **Suggestion:** Ensure error messages do not expose internal logic, filenames, or paths. Consider wrapping errors to provide only necessary context.

4. Insecure Protocol (`ErrInsecureProtocol`)

- **Security Concern:** Use of insecure protocols (HTTP).
- **Review:** The `ErrInsecureProtocol` error indicates that the code acknowledges the use of HTTP as insecure. However, the current code does not explicitly enforce HTTPS. If the `ParseModelPath` function accepts HTTP URLs, it may allow insecure communications.
- **Suggestion:** Enforce the use of HTTPS by validating the `ProtocolScheme` and rejecting or alerting when HTTP is used. Consider updating the validation logic in `ParseModelPath` to block non-HTTPS schemes.

5. MkdirAll Permissions

- **Security Concern:** File permissions should be set correctly.
- **Review:** The `os.MkdirAll` function is used with permission `0o755`, which allows read and execute permissions for all users and write permissions for the owner.
- **Suggestion:** While 755 is usually fine, in environments with strict security requirements, it might be better to limit permissions (e.g., `0o700`), especially for sensitive directories like `modelsDir`. This minimizes the risk of unauthorized users accessing those files.

6. Handling of External Input (Digest)

- **Security Concern:** Unsanitized inputs can lead to injection attacks or unintended file access.

- **Review:** In `GetBlobsPath`, the `digest` is directly used to construct a file path. While it replaces `:` with `-`, this may not be sufficient to prevent all forms of injection or path traversal attacks.
- **Suggestion:** Properly sanitize `digest` to ensure no dangerous characters are allowed (such as `..` or `/`). Validate it rigorously before using it to create file paths.

7. Use of `os.UserHomeDir()`

- **Security Concern:** Depending on user-provided directories.
- **Review:** The code uses the user's home directory when the `OLLAMA_MODELS` environment variable is not set. This is usually safe, but if the home directory permissions are too permissive, it might expose sensitive model files.
- **Suggestion:** Ensure that files stored in the user's home directory have appropriate access controls and that directory permissions are set correctly.

8. URL Handling

- **Security Concern:** Handling of URLs and remote resources.
- **Review:** The `BaseURL` function constructs a URL object but does not validate it. If the protocol scheme or registry is tampered with (via input), this might lead to unexpected connections or security issues (e.g., SSRF - Server-Side Request Forgery).
- **Suggestion:** Validate all parts of the URL, especially the protocol scheme and registry, ensuring they point to allowed locations.

Summary of Potential Vulnerabilities and Recommendations:

1. **Path Traversal:** Ensure input paths are validated and restricted to allowed directories.
2. **Environment Variables:** Validate and sanitize environment variables like `OLLAMA_MODELS`.
3. **Error Handling:** Avoid leaking sensitive information in error messages.
4. **Protocol Enforcing:** Enforce HTTPS and disallow HTTP for secure communications.
5. **File Permissions:** Use more restrictive permissions when creating directories (`0o700`).
6. **Digest Input Validation:** Sanitize and validate `digest` before using it in file paths.
7. **URL Validation:** Validate URL components (like scheme and registry) to prevent SSRF attacks.

By implementing these recommendations, you can improve the overall security of this Go code.

Provide the exact part of the code along with line numbers that are vulnerable or have security issues.

Here's a breakdown of the exact code sections with their respective line numbers that may have security concerns. I've indicated why each part of the code is vulnerable and what issues to address:

1. Path Traversal Risk in `ParseModelPath`

- **Line Numbers:** 32-35
- **Code:**

```
go

name = strings.ReplaceAll(name, string(os.PathSeparator), "/")
parts := strings.Split(name, "/")
```

- **Issue:** The code is manipulating path separators, which might introduce a path traversal vulnerability if the input `name` isn't properly validated. Attackers could potentially manipulate this to break out of intended directories.
- **Suggestion:** Sanitize the `name` variable to prevent injection of relative paths (e.g., `../`) and ensure the paths stay within allowed directories.

2. Insecure Environment Variable Usage (`OLLAMA_MODELS`)

- **Line Numbers:** 106-109
- **Code:**

```
go

if models, exists := os.LookupEnv("OLLAMA_MODELS"); exists {
    return models, nil
}
```

```
}
```

- **Issue:** The `OLLAMA_MODELS` environment variable is used without validation. An attacker can manipulate this variable to point to an unintended or insecure directory.
 - **Suggestion:** Validate the environment variable by ensuring it points to a safe and expected directory, or fall back to a default secure path.
-

3. Lack of HTTPS Enforcement in `ParseModelPath` and `BaseURL`

- **Line Numbers:**
 - In `ParseModelPath` : 28-31

```
go

before, after, found := strings.Cut(name, "://")
if found {
    mp.ProtocolScheme = before
    name = after
}
```

- In `BaseURL` : 137-141

```
go

func (mp ModelPath) BaseURL() *url.URL {
    return &url.URL{
        Scheme: mp.ProtocolScheme,
        Host:   mp.Registry,
    }
}
```

- **Issue:** These lines allow the `ProtocolScheme` to be set from the user input, which might include insecure protocols like `http`. Although there's an error for insecure protocols, there's no enforcement preventing the use of `http`.
- **Suggestion:** Add explicit validation to reject or block any protocol other than `https` to ensure secure communications.

4. Improper Permissions in `os.MkdirAll`

- Line Numbers:

- In `GetManifestPath()` : 147-150

```
go

if err := os.MkdirAll(path, 0o755); err != nil {
    return "", err
}
```

- In `GetBlobsPath()` : 163-167

```
go

if err := os.MkdirAll(dirPath, 0o755); err != nil {
    return "", err
}
```

- **Issue:** The `os.MkdirAll` function uses `0o755` permissions, which may be too permissive. This allows read and execute access for all users, and write access for the owner.
- **Suggestion:** Use more restrictive permissions, like `0o700`, especially if the directories are expected to contain sensitive files.

5. Digest Input in `GetBlobsPath()`

- Line Numbers: 159-161
- Code:

```
go

digest = strings.ReplaceAll(digest, ":", "-")
path := filepath.Join(dir, "blobs", digest)
```

- **Issue:** The `digest` input is used directly to construct a file path without thorough sanitization. Replacing `:` with `-` might not be sufficient to protect against path traversal or injection attacks.
 - **Suggestion:** Thoroughly validate the `digest` variable to ensure it only contains valid, expected characters, and cannot be used for directory traversal (e.g., `..`).
-

6. Error Handling in `Validate()`

- **Line Numbers:** 81-86
- **Code:**

```
go

if mp.Repository == "" {
    return fmt.Errorf("%w: model repository name is required",
errModelPathInvalid)
}

if strings.Contains(mp.Tag, ":") {
    return fmt.Errorf("%w: ':' (colon) is not allowed in tag names",
errModelPathInvalid)
}
```

- **Issue:** While not directly a security vulnerability, the error message here reveals internal logic and might expose more information than necessary in some contexts, such as logging or returning errors to users.
 - **Suggestion:** Ensure error messages are sanitized or appropriately logged to prevent leaking sensitive internal details.
-

Summary of Exact Lines with Issues:

Line Numbers	Code Section	Issue
32-35	Path Separator Replacement in <code>ParseModelPath</code>	Potential for Path Traversal

Line Numbers	Code Section	Issue
106-109	Use of <code>OLLAMA_MODELS</code> Env Variable	Possible Insecure Directory Manipulation
28-31, 137-141	Protocol Handling (<code>ParseModelPath</code> & <code>BaseURL</code>)	No HTTPS Enforcement
147-150, 163-167	<code>os.MkdirAll</code> Permissions	Too Permissive Directory Permissions (755)
159-161	Use of <code>digest</code> in <code>GetBlobsPath()</code>	Insufficient Input Validation (Path Injection)
81-86	Error Handling in <code>Validate()</code>	Potential Information Leakage

By addressing these concerns and following the suggestions provided, you can significantly improve the security posture of your Go code.

Please analyze the code for common security vulnerabilities if present and map them to OWASP Top 10 Web Application Security Risk category/categories.

Here's an analysis of the Go code, mapped to potential security vulnerabilities that align with the **OWASP Top 10 Web Application Security Risks**. Each finding is explained with respect to its OWASP category and relevant code sections.

1. Path Traversal Vulnerability (OWASP A06:2021 - Vulnerable and Outdated Components)

- **Issue:** The code manipulates paths based on input without sufficient sanitization.
- **Code:**

```
go

name = strings.ReplaceAll(name, string(os.PathSeparator), "/")
parts := strings.Split(name, "/")
```

- **Line Numbers:** 32-35

- **Explanation:** This code replaces OS-specific path separators with `/`, which can be exploited if an attacker passes input like `../../../../` to traverse directories. This could allow access to files outside the intended directory, a common path traversal attack.
 - **OWASP Mapping:** A06 (Vulnerable and Outdated Components) — Although not specific to outdated libraries, improper handling of file paths and failure to sanitize inputs can allow access to sensitive files. This falls under misconfiguration and improper file access handling.
 - **Suggested Fix:** Implement strict validation of paths and restrict them to specific allowed directories using absolute paths or sandboxed file handling techniques.
-

2. Insecure Usage of Environment Variables (OWASP A04:2021 - Insecure Design)

- **Issue:** The `OLLAMA_MODELS` environment variable is used without validation.
- **Code:**

```
go

if models, exists := os.LookupEnv("OLLAMA_MODELS"); exists {
    return models, nil
}
```

- **Line Numbers:** 106-109
 - **Explanation:** This code relies on an environment variable to determine a file path without validating it. If an attacker has control over the environment, they could set the variable to point to sensitive directories or introduce security vulnerabilities.
 - **OWASP Mapping:** A04 (Insecure Design) — The failure to validate environment variables results in potential insecure configurations or directory access.
 - **Suggested Fix:** Validate the value of the `OLLAMA_MODELS` environment variable, ensuring it points to a safe, predefined directory. If the variable is not set, default to a secure path.
-

3. Use of Insecure Protocols (OWASP A06:2021 - Vulnerable and Outdated Components / A02:2021 - Cryptographic Failures)

- **Issue:** The `ProtocolScheme` can be set to `http`, which is insecure.
- **Code:**

```
go

before, after, found := strings.Cut(name, "://")
if found {
    mp.ProtocolScheme = before
    name = after
}
```

- **Line Numbers:** 28-31
- **Explanation:** The code allows the use of protocols like HTTP without enforcing secure protocols like HTTPS. Even though the error `ErrInsecureProtocol` is defined, the program does not block or enforce the use of HTTPS.
- **OWASP Mapping:**
 - **A02 (Cryptographic Failures)** — The failure to enforce HTTPS can lead to insecure communication where sensitive data is exposed in transit.
 - **A06 (Vulnerable and Outdated Components)** — Using insecure or improper configurations can result in data leaks or vulnerability to attacks like man-in-the-middle (MITM).
- **Suggested Fix:** Enforce the use of HTTPS in `ParseModelPath` and ensure that any insecure protocols like HTTP are rejected. Use a whitelist approach to only allow secure protocols.

4. Insufficient File Permissions (OWASP A05:2021 - Security Misconfiguration)

- **Issue:** `os.MkdirAll` is used with the default permission of `0o755`, which might be too permissive.
- **Code:**

```
go
```

```
if err := os.MkdirAll(path, 0o755); err != nil {  
    return "", err  
}
```

- **Line Numbers:** 147-150, 163-167
- **Explanation:** Creating directories with `0o755` gives read and execute access to all users. This can expose sensitive files and directories to unauthorized users on the system.
- **OWASP Mapping:** A05 (Security Misconfiguration) — Incorrect file and directory permissions can allow unauthorized access to sensitive resources or modify system behavior in unexpected ways.
- **Suggested Fix:** Use more restrictive permissions like `0o700` to limit access only to the owner and ensure that sensitive directories are not exposed to unauthorized users.

5. Lack of Input Validation on Digest Input (OWASP A01:2021 - Broken Access Control / A03:2021 - Injection)

- **Issue:** The `digest` input is used to construct a file path without proper sanitization.
- **Code:**

```
go
```

```
digest = strings.ReplaceAll(digest, ":", "-")  
path := filepath.Join(dir, "blobs", digest)
```

- **Line Numbers:** 159-161
- **Explanation:** The input `digest` is minimally sanitized by replacing `:` with `-`. However, this is not sufficient to prevent path traversal or injection attacks. For example, an attacker could inject `../` to access files outside the intended directory.
- **OWASP Mapping:**
 - **A01 (Broken Access Control)** — The failure to sanitize the `digest` input could allow unauthorized access to file paths outside the intended scope.

- **A03 (Injection)** — Using unsanitized input to construct file paths can lead to directory traversal or command injection attacks.
 - **Suggested Fix:** Properly sanitize the `digest` input by ensuring it only contains valid characters and does not allow traversal characters like `...`. Validate it rigorously before using it in any file operations.
-

6. Potential Information Exposure in Error Messages (OWASP A01:2021 - Broken Access Control / A03:2021 - Injection)

- **Issue:** Error messages may leak sensitive details about internal logic.
- **Code:**

```
go

return fmt.Errorf("%w: model repository name is required", errModelPathInvalid)
```

- **Line Numbers:** 81-86
 - **Explanation:** Error messages that reveal too much about internal logic (such as path structures or details of invalid input) can help an attacker craft more precise attacks.
 - **OWASP Mapping:**
 - **A01 (Broken Access Control)** — Leaking detailed error information can help an attacker bypass security controls by understanding the internal behavior of the system.
 - **A03 (Injection)** — Detailed errors may help an attacker identify potential vectors for injection attacks.
 - **Suggested Fix:** Sanitize error messages or provide generic error messages when dealing with user-facing functions to avoid leaking details about internal workings.
-

Summary of OWASP Top 10 Mappings:

Vulnerability	OWASP Category
Path Traversal Vulnerability	A06:2021 - Vulnerable and Outdated Components
Insecure Environment Variables	A04:2021 - Insecure Design
Use of Insecure Protocols (HTTP instead of HTTPS)	A02:2021 - Cryptographic Failures / A06:2021 - Vulnerable Components
Insufficient File Permissions	A05:2021 - Security Misconfiguration
Lack of Input Validation on Digest Input	A01:2021 - Broken Access Control / A03:2021 - Injection
Potential Information Exposure in Error Messages	A01:2021 - Broken Access Control / A03:2021 - Injection

General Suggestions:

- **Input Validation:** Ensure all user inputs (including path elements and environment variables) are thoroughly validated and sanitized to prevent injection and path traversal vulnerabilities.
- **Error Handling:** Avoid exposing internal system details in error messages. Provide generic error messages when interacting with external users.
- **Secure Protocol Enforcement:** Enforce the use of HTTPS for all communication to prevent exposure of sensitive data.
- **File and Directory Permissions:** Use the least-privilege principle when setting file and directory permissions, especially for sensitive directories.

By addressing these vulnerabilities, you can significantly improve the security of your Go application.